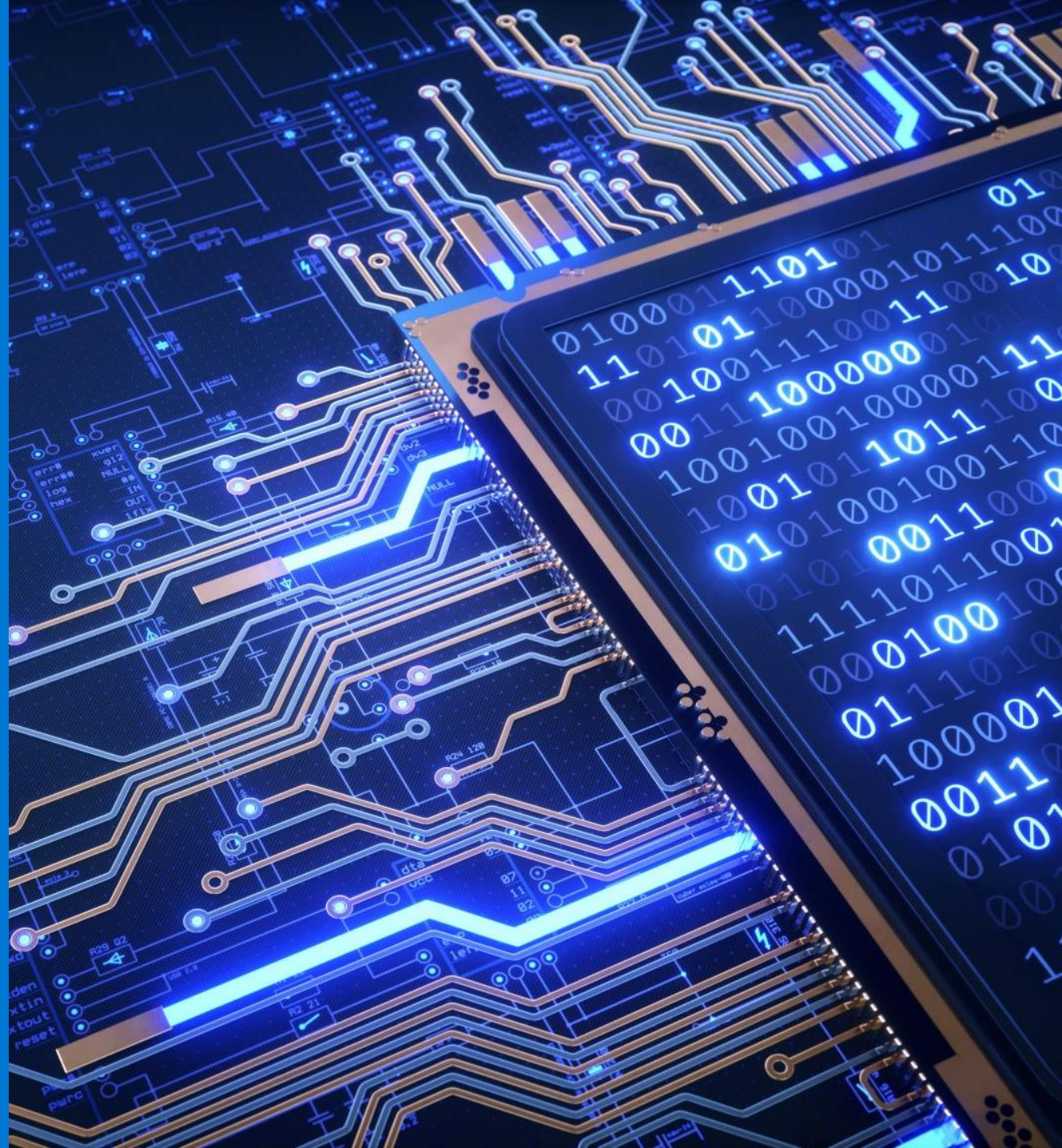
How Zero Trust can help your organization keep safe

BATBern

11.11.2022

Nathalie Mombelli – Enterprise Security Executive



Agenda

Why Zero Trust?

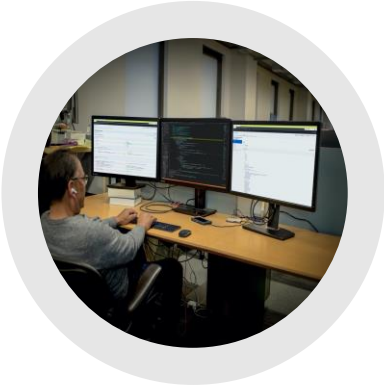
Zero Trust Goal, Principles & Benefits

Zero Trust Components & Architecture

Implementing Zero Trust

Experience of different customers

Why Zero Trust?



Evolving threat landscape

- Initial attacks not anymore network-based
- Increase of the attack surface
- 80% of breaches involve lost / stolen credentials
- More sophisticated and devastating attacks

Changing business environment

- Increasing number of data, devices, users, connections, identities
- Multiple IT platforms
- Evolving technologies and regulations
- Complexity and disruption
- Lack of resources and skills
- Strong pressure on costs

Network perimeter has disappeared

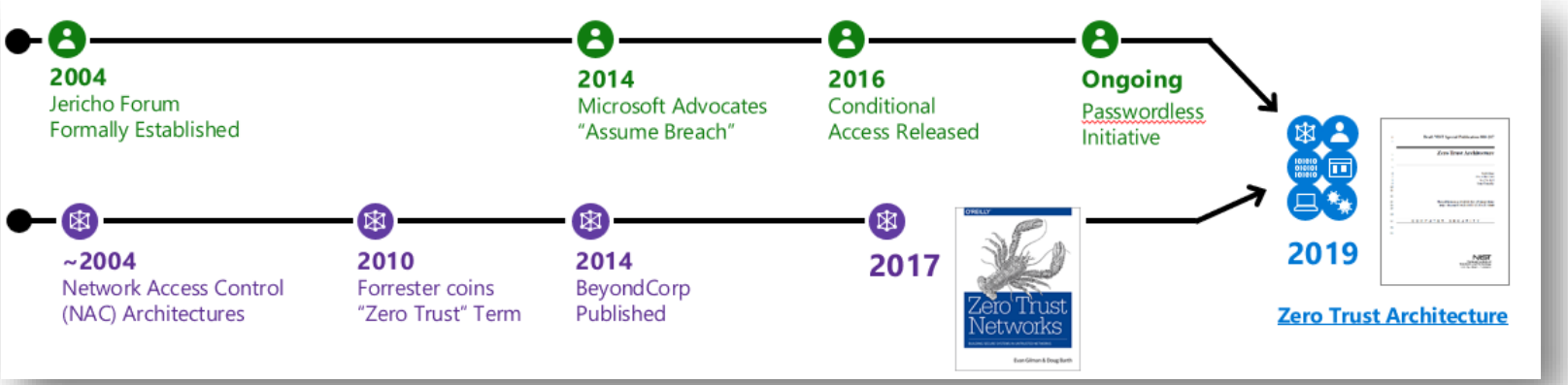
- IT/OT assets have left the classical network perimeter
- Remote work is set
- Loss of control on devices, data and network (BYOD, Mobile, SaaS, IoT/OT)
- Supply chain attacks

Attackers shift to identity attacks

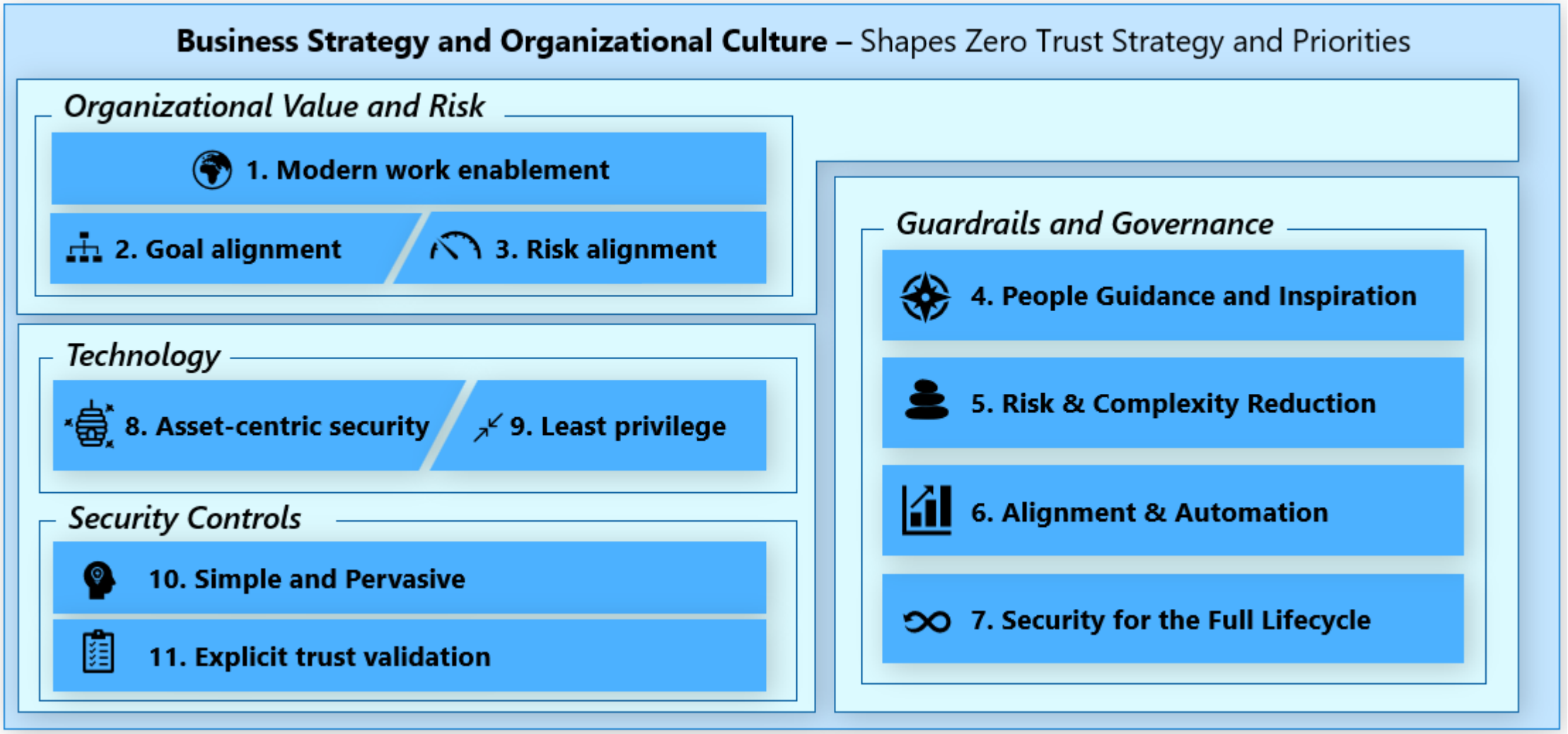
Nowadays cyber criminals do not break in - they log in!

Zero Trust Overview

- Zero Trust assumes **an open environment** where the **identity and security posture** of each access request must be continuously evaluated and validated;
- Access is granted through a **Policy Decision Point and Policy Enforcement Point** and is **minimized** to resources which are validated as **needing access**;
- **Context is important** (→ data points on user behavior, device compliance, location, time of day, target application or service, etc.);
- Zero Trust is a **framework, culture and philosophy**, not a technical solution;
- Implementing Zero Trust is a **journey**, not a destination.



Zero Trust Core Principles



Source: [Zero Trust Core Principles (opengroup.org)]

What Business expects from Zero Trust Projects?

Line of Business

- **Business Agility –** for continuous business environment changes:
  - Business Models and partnerships
  - Technology trends
  - Regulatory, geopolitical, cultural forces
  - Disruptive events
  - Shift to remote work
- **Accelerate digital transformation and lower risk**

Business Support
(Finance, HR, etc.)

- **Accelerate process modernization** using cloud technologies
- **Rapidly apply policy** as people change roles
  Employee ←→ supplier ←→ partners
- **Better business risk visibility & mitigation** throughout the whole organization

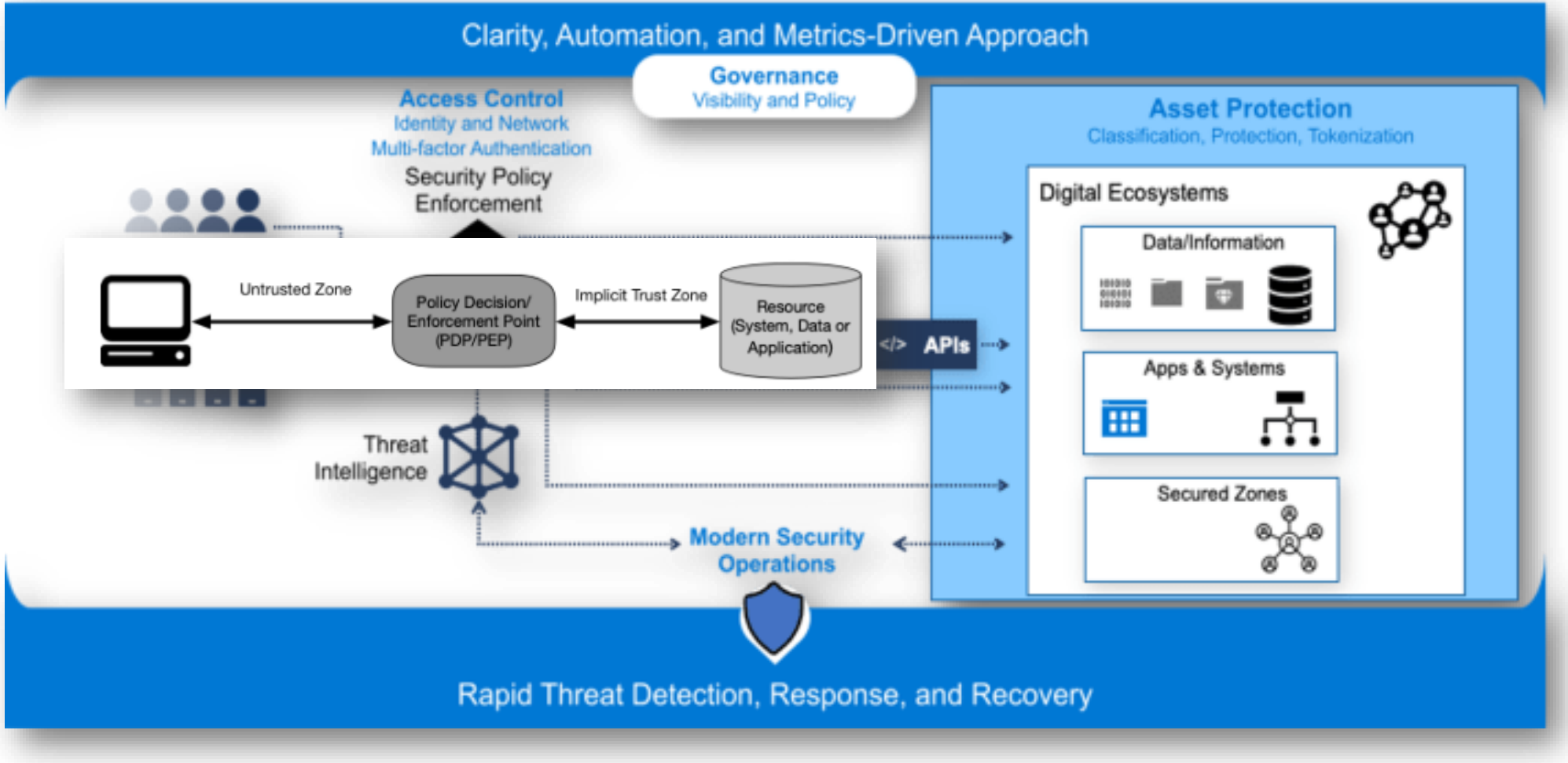
IT & Security

- **Simpler architectures** are more cost effective, easier to support, and reduce the threat surface
- **Less policy exceptions** and escalations to manage
- **Better visibility** into technical risks
- **Better prevention** of common security risks

Better security, compliance, agility, efficiency, productivity and **attractiveness** as employer

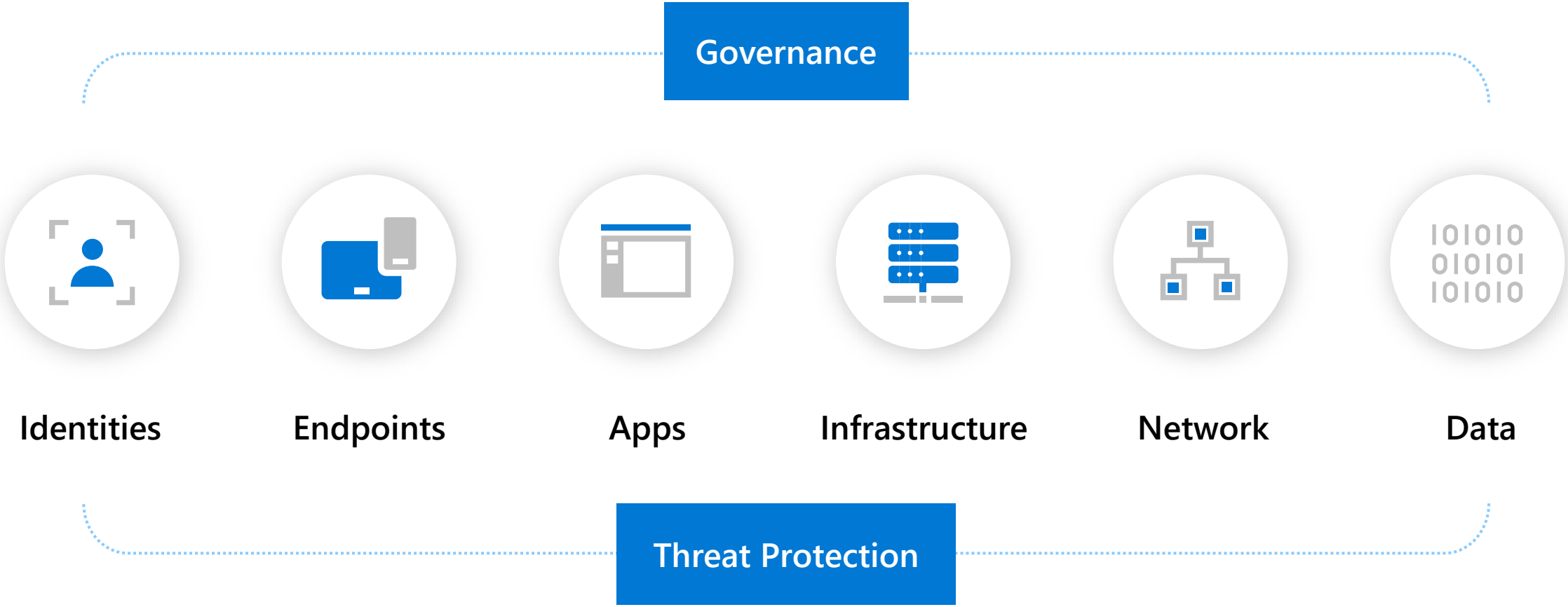
Zero Trust Components

Enable flexible business workflows for the digitized world

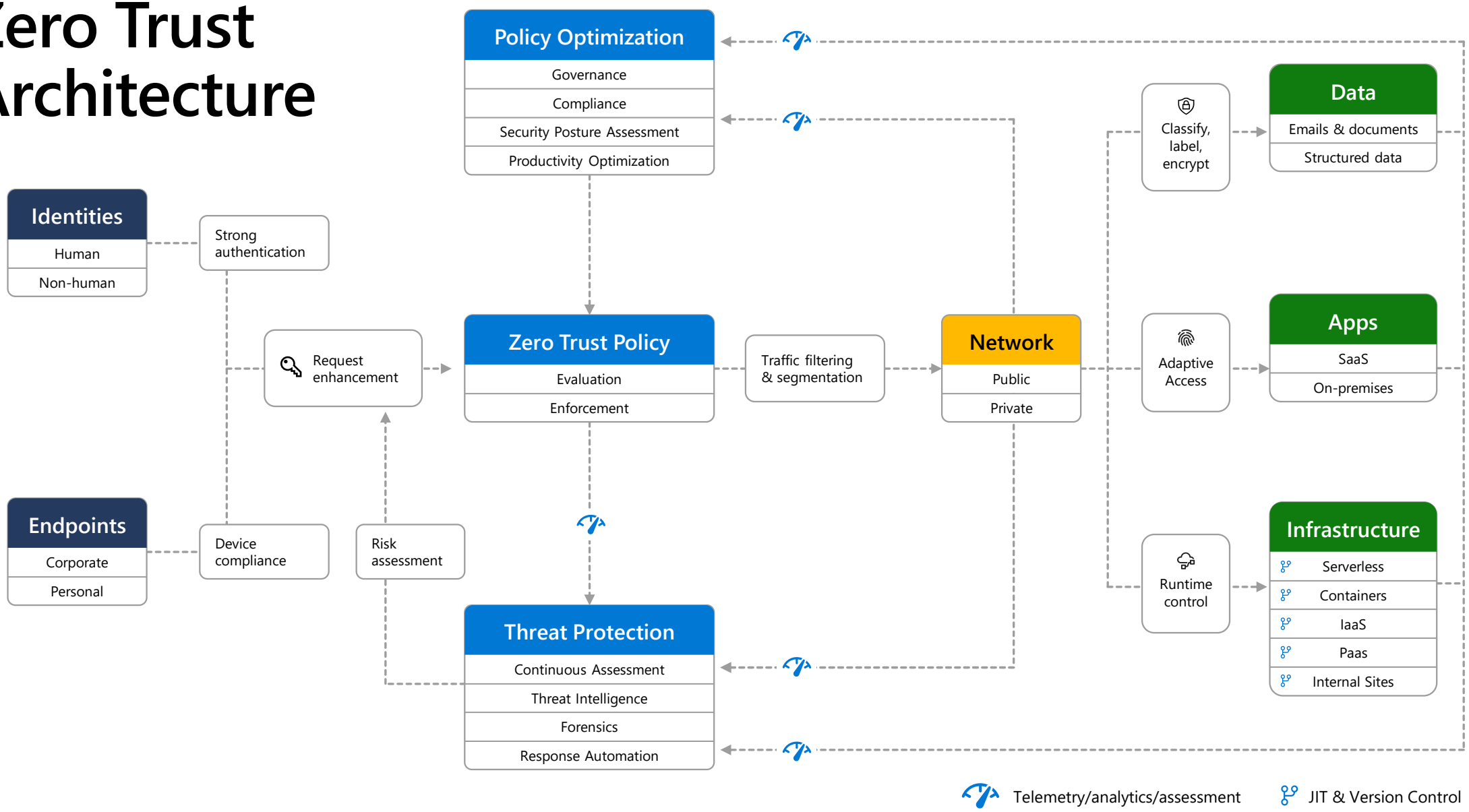


Source: [The Open Group Zero Trust Initiative and The President's Executive Order on Improving the Nation's Cybersecurity – The Open Group Blog]

Zero Trust Pillars



Zero Trust Architecture



Where do Zero Trust Projects usually Start?

- Zero Trust is a journey across all security risk areas to be completed over time
- Organizations start the implementation in different places. They need to identify the individual components of each security risk area to prioritize, usually the following ones:

Identities	
Strong authentication (i.e., multi-factor authentication, passwordless authentication)	32%
Automated risk detection and remediation	27%
Adaptive access policies to gate access to resources	22%

Endpoints	
Data Loss Prevention policies/controls for all unmanaged and managed devices	27%
Real-time device risk evaluation / endpoint threat detection	26%
Devices are registered with identity provider	24%

Apps	
Ongoing Shadow IT Discovery and risk assessment	23%
Granular access control to your apps (such as limited visibility or read only)	22%
Policy-based access control for apps	20%

Infrastructure	
Security operations team access to threat detection tools	25%
Cloud workload protection across hybrid and multi-cloud	19%
Granular visibility and access control across all workloads (virtual machines, servers, etc.)	17%

Data	
Access decisions are governed by security policy engine	21%
Data is classified and labeled	21%
The most sensitive files are persistently protected with encryption	20%

Network	
Secure access controls to protect networks	25%
Threat protection and filtering with context-based signals	24%
All traffic is encrypted	20%

Zero Trust components that are usually implemented first

How should Zero Trust Initiatives be Prioritized?

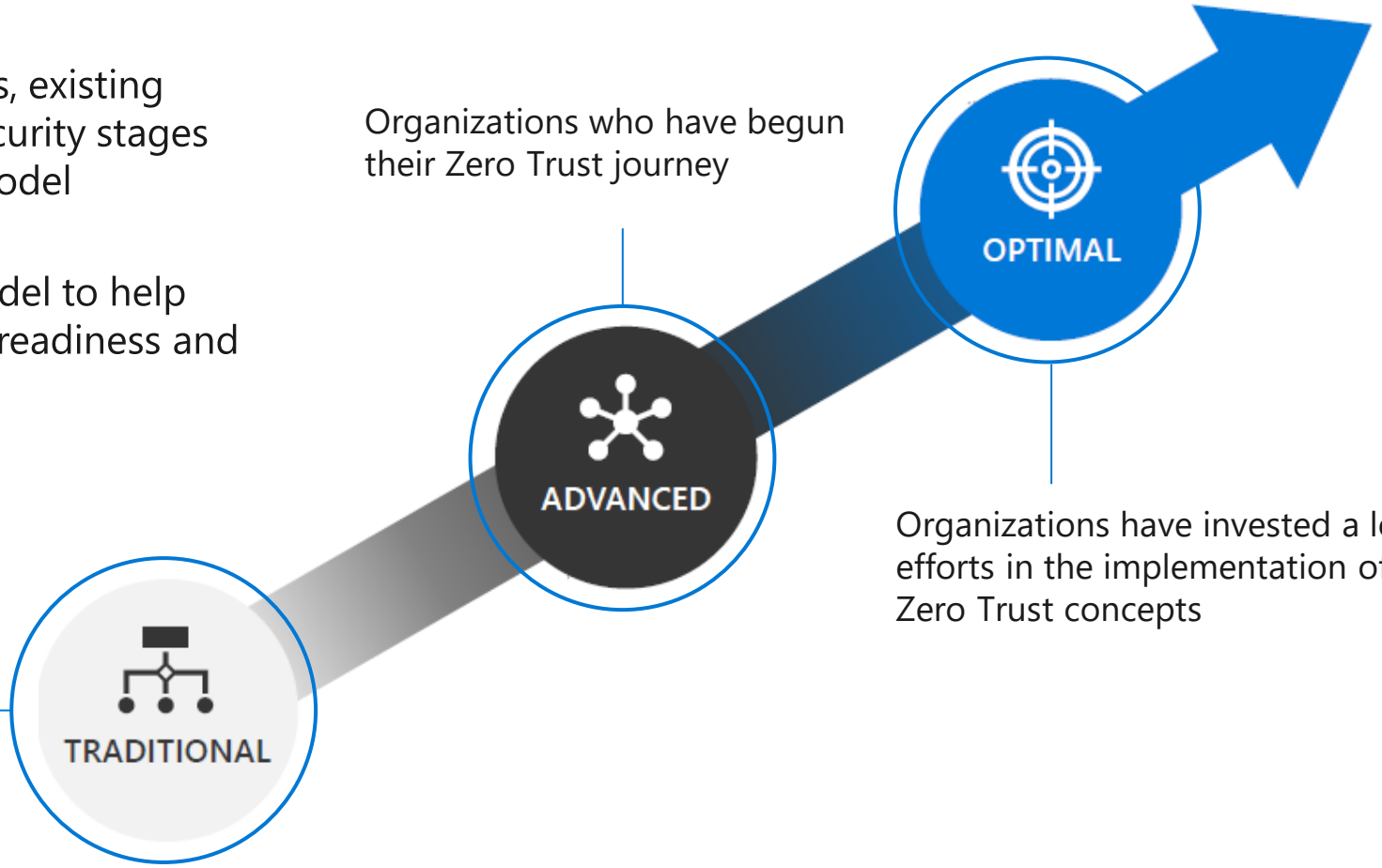
- Define criteria to ensure a clear and consistent prioritized approach
- Balance security, functionality, and usability
- Understand what is the most important for your organization (alignment with business goals)

Common prioritization criteria
Estimated Security Value (threat modelling, risk appetite of the organization)
Implementation effort
Available resources (staff, skilling, budget)
Number of users affected
Required licensing types and costs
Estimated productivity value and alignment with business mission
End-User impact (low, medium, high)
Legacy systems displacement (usually driven by cost reduction)

Microsoft Zero Trust Maturity Model

A three-stage [maturity model]

- Different organizational requirements, existing technology implementations, and security stages all affect how a Zero Trust security model implementation is planned.
- We have developed this maturity model to help organizations assess their Zero Trust readiness and build a plan to get to Zero Trust.



Zero Trust Maturity Assessment

https://www.microsoft.com/en-us/security/business/zero-trust/maturity-model-assessment-tool

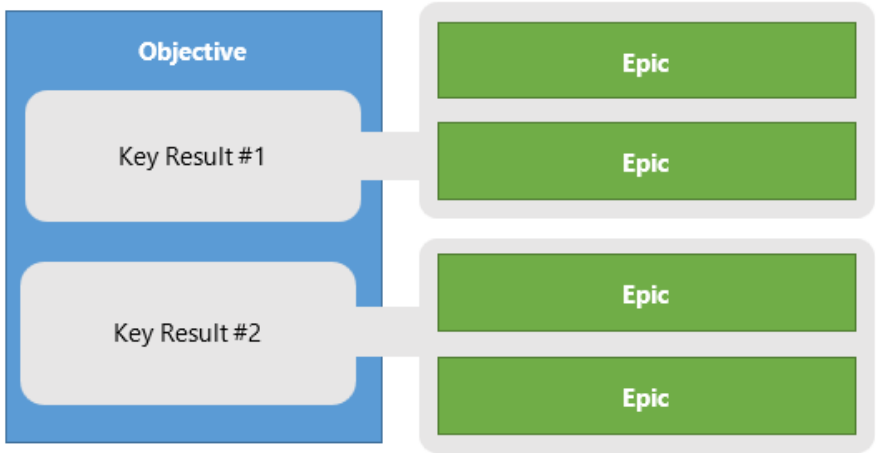
Zero Trust Maturity Model Capabilities

	Traditional	Advanced	Optimal
Identities	• On-premises identity provider is in use • No SSO is present between cloud and on-premises apps • Visibility into identity risk is very limited	• Cloud identity federates with on-premises system • Conditional access policies gate access and provide remediation actions • Analytics improve visibility	• Passwordless authentication is enabled • User, device, location, and behavior is analyzed in real time to determine risk and deliver ongoing protection
Devices	• Devices are domain joined and managed with solutions like Group Policy Object or Config Manager • Devices are required to be on network to access data	• Devices are registered with cloud identity provider • Access only granted to cloud managed & compliant devices • DLP policies are enforced for BYO and corporate devices	• Endpoint threat detection is used to monitor device risk • Access control is gated on device risk for both corporate and BYO devices
Apps	• On-premises apps are accessed through physical networks or VPN • Some critical cloud apps are accessible to users	• On-premises apps are internet-facing and cloud apps are configured with SSO • Cloud Shadow IT risk is assessed; critical apps are monitored and controlled	• All apps are available using least privilege access with continuous verification • Dynamic control is in place for all apps with in-session monitoring and response
Infrastructure	• Permissions are managed manually across environments • Configuration management of VMs and servers on which workloads are running	• Workloads are monitored and alerted for abnormal behavior • Every workload is assigned app identity • Human access to resources requires Just-In-Time	• Unauthorized deployments are blocked and alert is triggered • Granular visibility and access control are available across all workloads • User and resource access is segmented for each workload
Network	• Few network security perimeters and flat open network • Minimal threat protection and static traffic filtering • Internal traffic is not encrypted	• Many ingress/egress cloud micro-perimeters with some micro-segmentation • Cloud native filtering and protection for known threats • User to app internal traffic is Encrypted	• Fully distributed ingress/egress cloud micro-perimeters and deeper micro-segmentation • ML-based threat protection and filtering with context-based signals • All traffic is encrypted
Data	• Access is governed by perimeter control, not data sensitivity • Sensitivity labels are applied manually, with inconsistent data Classification	• Data is classified and labeled via regex/keyword methods • Access decisions are governed by encryption	• Classification is augmented by smart machine learning models • Access decisions are governed by a cloud security policy engine • DLP policies secure sharing with encryption and tracking

Delivering with Objectives and Key Results (OKRs)

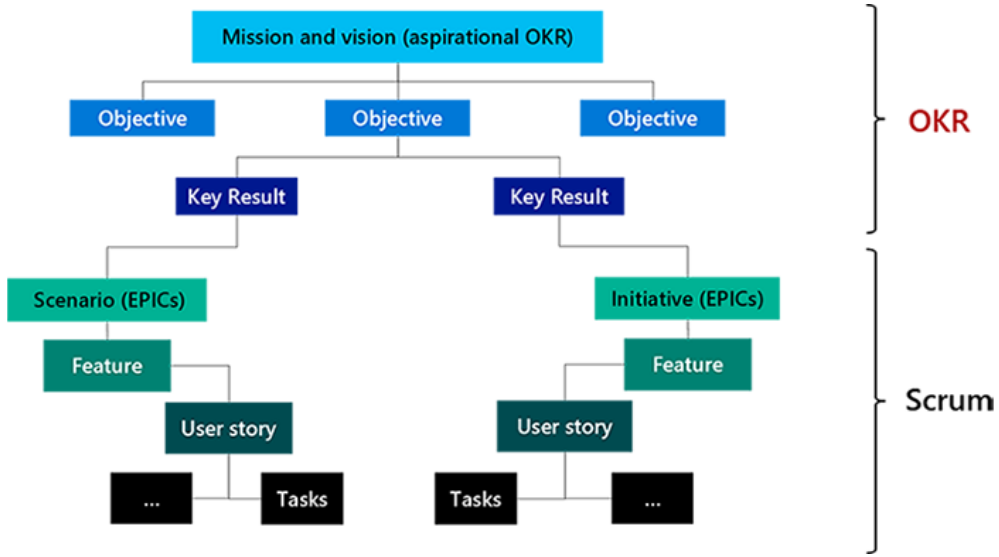
Three Essential Aspects

1. OKRs make up a framework for defining **clear objectives**, providing clarity on the **intent** and **direction** at all levels in the organization.
2. They are reinforced with **measurable key results**. Key results are outcomes by which **success** is measured.
3. They drive an **outcome mindset culture**, enabling a clear shift from an output mindset to an outcome mindset.



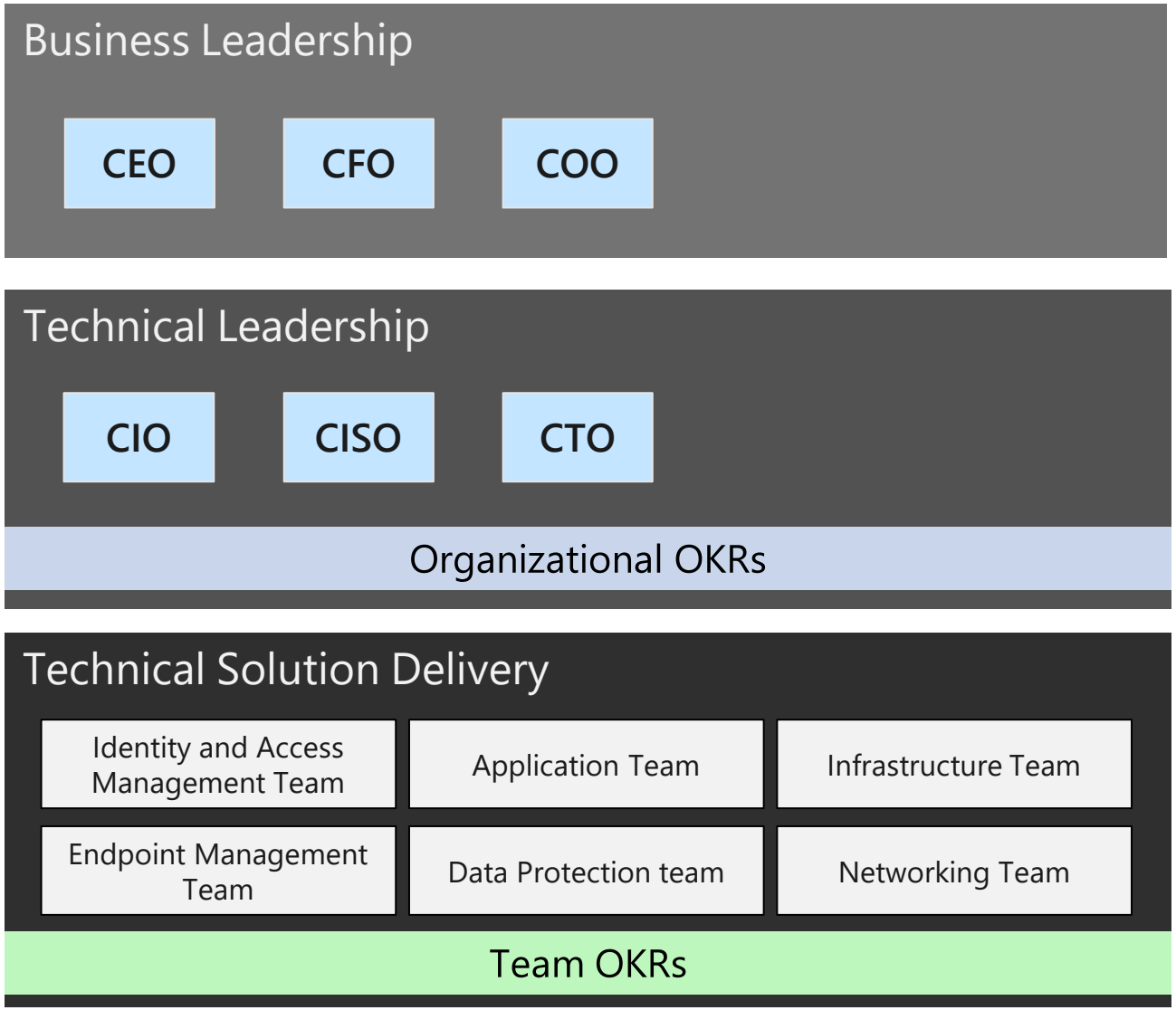
EPICs and OKRs must be aligned

EPICs can spin up one or more initiatives to implement the OKR



Reference: [Explore Continuous Planning - Training | Microsoft Learn]

Organizational and Team OKRs



Digital Transformation

Business Drivers and Benefits

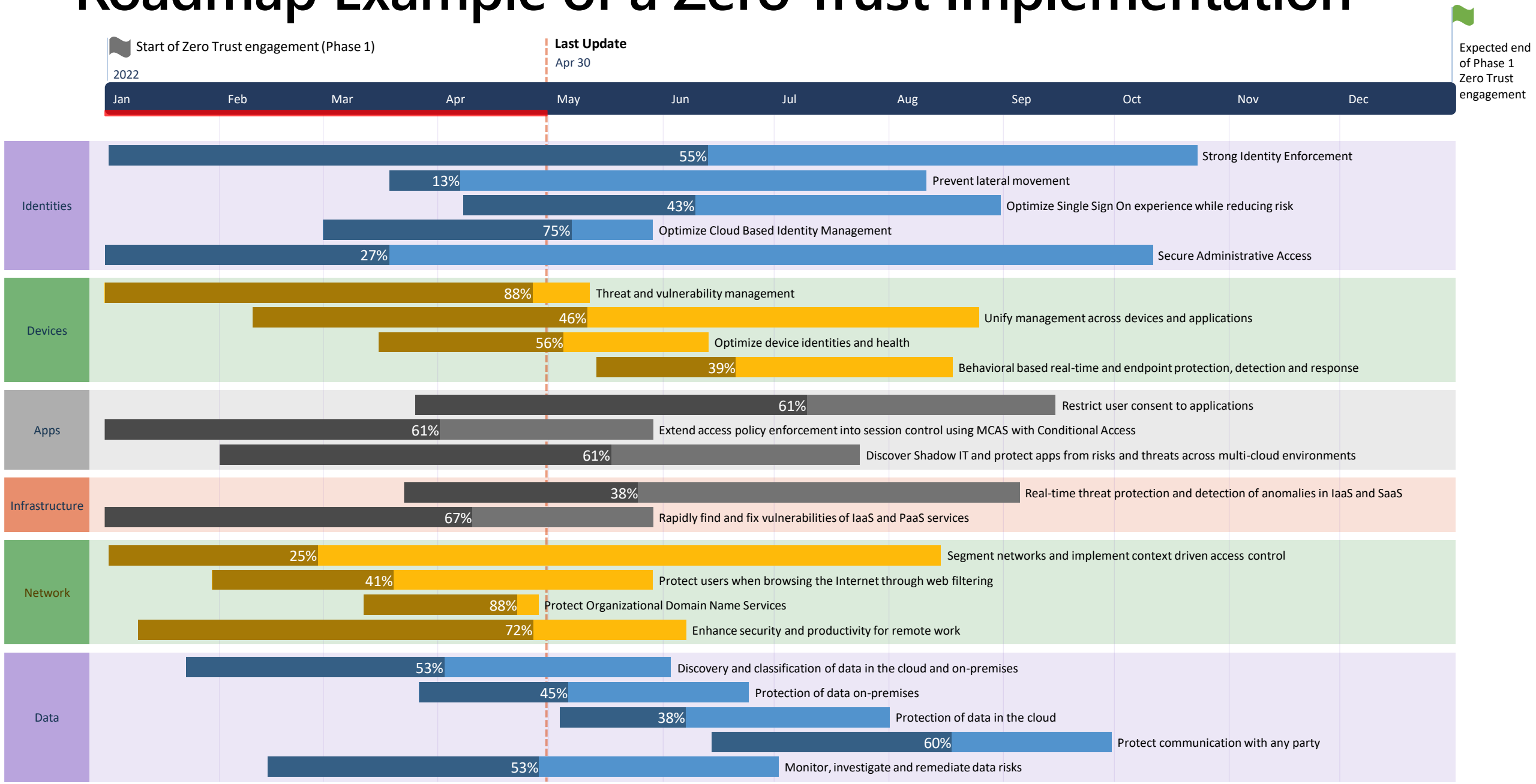
Zero Trust Strategy

Enterprise Strategy and Priorities

Zero Trust Implementation

Technical Architecture and Implementation

Roadmap Example of a Zero Trust Implementation



Experience on Implementing Zero Trust @UBS

Return of experience from an Enterprise Architect @ UBS

Zero Trust is a **cloud adoption project**. Increasing the flexibility and scalability of their technology infrastructure is critical to UBS's strategy. Therefore, UBS has defined a cloud-first strategy. This goal is supported by a strategic partnership with Microsoft and the implementation of Zero Trust. Through this transformational initiative, UBS plans to modernize their global technology estate and have more than 50% of its applications, including critical workloads, running on Microsoft Azure.

Their Zero Trust architecture based on **NIST Zero Trust Architecture and SASE**. It has been clear to them for many years that network perimeter no longer exists and that **identity is the new perimeter**. Conditional access to apps and sensitive data (customer data) is determined by PDP/PEP.

Due to regulatory requirements, they had to centralize Identity & Access Management 20 years ago already. In the meantime, they have implemented internet-based identity with Azure AD.

In 2021, their CTO ordered a review on their Zero Trust architecture. They wanted to define where they were on their ZT journey. Different initiatives (like network modernization) have been initiated. The review was made independently from any technology.

Zero Trust implementation is a journey and a **continuous process**. They constantly need to adapt to technology changes, new risks and organizational needs.

Challenges:
- Costs for the consolidation were underestimated
- Standardization regarding modern authentication with conditional access was a "cultural" shift
- Adoption of business users (MFA and AAD is more intrusive for them)
- Ensure implementation of ZT principles throughout the whole organization (minimal Enterprise requirements defined, but not checked if ZT applied)

Zero Trust remains to 95% an IT project and topic (technology, network, Hosting Services, agile transformation).

Drivers & Benefits of Implementing Zero Trust

Our survey on Zero Trust adoption shows that:

Top Motivators	
Improve overall security posture	47%
Improve end user experience and productivity	44%
Transform the way security teams work together	38%
Simplify security stack	35%
Reduce security costs	35%

Source: [Zero Trust Adoption Report: How does your organization compare? - Microsoft Security Blog]

Challenges & Blockers while Implementing Zero Trust

Resource Challenges 60%	Leadership 53%	Technological 46%	Vendor 46%	Budget Constraints 45%
20% Takes too long to implement	20% Lack of support from wider C-suite leadership	21% Difficulty integrating security solutions	21% Need implementation support from vendors	21% Cost of implementing a Zero Trust strategy
19% Lack of internal change management	19% Lack of support from stakeholders	19% Incompatibility with legacy systems	21% Difficulty identifying the right vendors	21% Difficulty proving ROI
18% Need more education materials	19% Need help to make a compelling business case	19% Difficulty scaling throughout the organization	17% Inability to find innovative partners	14% Don't have a large enough budget
17% Not needed for an organization of our size	18% Lack of organizational buy-in			
16% Don't have the right talent to properly implement				

Source: [Zero Trust Adoption Report: How does your organization compare? - Microsoft Security Blog]

Thank you for your attention.

Questions?

© Copyright Microsoft Corporation. All rights reserved.